

Message Retargeting in the NGCC CompactSQUIsign2D2 Submission

A One-Query Fresh-Message Forgery Across All Eight Parameter Sets

Martin Feussner
Selmer Center, University of Bergen
`martin.feussner@uib.no`

28 September 2026

Provenance and review status. The attack was independently found by an AI system, OpenAI Codex using Daybreak Blue at maximum reasoning effort, without a human first proposing this specific signature attack. The AI also produced the derivation, implementation, experiments, and initial manuscript. At the date above, no human cryptanalyst has independently verified the argument, implementation, measurements, or novelty assessment. This preliminary disclosure is provided for human review and reproduction.

Abstract

The compact mode in the NGCC SQUIsign2D2 submission serializes both a description of the dual challenge isogeny and a Fiat–Shamir challenge scalar. Its verifier reconstructs a challenge curve from the response, follows the transmitted dual path back to a commitment curve, hashes that commitment with the public key and message, and compares the result with the transmitted scalar. The scalar never constrains either isogeny path. In particular, verification omits the condition that the forward isogeny selected by the hash-derived scalar has the reconstructed challenge curve as its codomain.

This omission gives a deterministic one-query EUF-CMA forgery against the submitted compact mode. From one valid signature, an attacker publicly reconstructs the same commitment curve, hashes it with any fresh target message, and replaces only the serialized challenge field. Every geometric check receives its original input, while the final hash comparison now holds for the target message. No collision, second preimage, secret isogeny, or equivalent key is required.

An independent implementation of this transform against the unmodified reference sources produced 24 accepted fresh-message forgeries: three for each of the eight submitted compact parameter sets. Negative controls rejected the untouched signature on each target and the retargeted signature on its source message; byte comparisons found no change outside the challenge field. Median forgery times ranged from 20 milliseconds to 1.98 seconds on an Intel Core i5-6500 laptop. The flaw is present in the NGCC verification algorithm and implementation. It is not a claim against the original 2025 CompactSQUIsign2D2 construction, whose verification algorithm includes a separate equality binding the hash-derived forward kernel to the transmitted dual path.

1 Introduction

SQUIsign2D2 is an isogeny-based Fiat–Shamir signature submitted to the Next-generation Commercial Cryptographic Algorithms Program in both uncompressed and compact modes [1]. At a high level, the signer commits to a curve E_{com} , derives a scalar

$$c = \text{HASH}(pk \parallel j(E_{\text{com}}) \parallel m),$$

and uses c to select a 3^b -isogeny from E_{com} to a challenge curve E_{chl} . A response isogeny connects the public-key curve to the same E_{chl} . Sound Fiat–Shamir verification must bind these three objects: the response, the commitment, and the hash-derived challenge [4].

The NGCC compact mode reconstructs rather than transmits the commitment curve. Its signature contains data from which the verifier obtains E_{chl} and a scalar description of the dual challenge isogeny

$$\hat{\phi} : E_{\text{chl}} \longrightarrow E_{\text{com}}.$$

It also serializes c . The verifier follows $\hat{\phi}$ to obtain E_{com} and checks that the serialized c equals the hash of the message and this curve. It does not verify that c selects the forward isogeny dual to $\hat{\phi}$.

This distinction is decisive. In the submitted verification relation, the response and dual-path data are independent of the serialized field at verification time. Once a valid tuple has passed all geometric conditions, the attacker may recompute only the detached hash field for a different message. The same response then authenticates every target message.

The attack has the following properties.

1. It is a fresh-message forgery in the standard EUF-CMA game, using one signing query.
2. It succeeds deterministically for any fresh target message and every submitted compact parameter set.
3. It requires only computations already performed by public verification.
4. It changes one contiguous field of a valid serialized signature and leaves the full isogeny response unchanged.
5. It does not rely on malformed curves, unchecked inputs, assertion behavior, or any previously reported implementation issue.

Section 2 isolates the relevant part of compact signing and verification. Section 3 gives the transform and proves the forgery. Section 4 reports validation against all eight reference implementations. Section 5 distinguishes the NGCC submission from the original published compact construction and from other public findings, and Section 6 gives a repair condition.

2 The compact construction

We use only the interfaces needed for the attack. The internal quaternion and two-dimensional-isogeny computations are irrelevant.

2.1 Commitment and forward challenge

The signer samples a commitment curve E_{com} and obtains a canonical basis $(R_{\text{com}}, S_{\text{com}})$ of its 3^b -torsion. It computes

$$c = \text{HASH}(pk \parallel j(E_{\text{com}}) \parallel m) \in \mathbb{Z}/3^b\mathbb{Z} \tag{1}$$

and the challenge isogeny

$$\phi_c : E_{\text{com}} \longrightarrow E_{\text{chl}}, \quad \ker(\phi_c) = \langle R_{\text{com}} + [c]S_{\text{com}} \rangle. \tag{2}$$

This is Algorithm 3.5, lines 14–15, of the submission specification. The response is then constructed so that its relevant codomain is the same curve E_{chl} .

For compact encoding, the signer computes the dual path

$$\hat{\phi}_c : E_{\text{chl}} \longrightarrow E_{\text{com}}. \tag{3}$$

Relative to a canonical 3^b -torsion basis $(R_{\text{chl}}, S_{\text{chl}})$, its kernel is encoded by a projective scalar t and a selector g :

$$\ker(\hat{\phi}_c) = \begin{cases} \langle R_{\text{chl}} + [t]S_{\text{chl}} \rangle, & g = 0, \\ \langle [t]R_{\text{chl}} + S_{\text{chl}} \rangle, & g = 1. \end{cases}$$

The remaining compact data, denoted below by ρ , describes the response and supplies the hints and matrices from which the verifier recovers E_{chl} .

The submitted byte encoding is therefore conveniently written

$$\sigma = (\rho, t, g, c). \quad (4)$$

Here ρ includes the transmitted curve, response matrix, curve-selection bit, and basis hints. The exact names of these fields do not affect the attack.

2.2 Compact verification

Algorithm 3.6 of the NGCC specification and the reference implementation perform the following operations.

1. From pk and ρ , compute a dimension-two isogeny and select its indicated elliptic factor as E_{chl} .
2. From E_{chl} and (t, g) , evaluate the 3^b -isogeny in Equation (3) and call its codomain E_{com} .
3. Compute $c^* = \text{HASH}(pk \parallel j(E_{\text{com}}) \parallel m)$ and test $c = c^*$.
4. Perform any remaining validity and common-part checks on the response and the encoded dual path.

Let

$$(E_{\text{chl}}, E_{\text{com}}) = \text{Recover}(pk, \rho, t, g) \quad (5)$$

denote the first two steps. Crucially, **Recover** does not take c or m as input. All remaining geometric checks are also independent of c and m . Consequently there is a predicate P such that the implemented acceptance condition has the form

$$\text{Verify}(pk, m, (\rho, t, g, c)) = 1 \iff P(pk, \rho, t, g) = 1 \wedge c = \text{HASH}(pk \parallel j(E_{\text{com}}) \parallel m). \quad (6)$$

Equation (6) checks that c is a digest of the reconstructed commitment, but it does not use c to check the challenge isogeny. The omitted condition is

$$E_{\text{chl}} \cong \text{Codom}(E_{\text{com}} / \langle R_{\text{com}} + [c]S_{\text{com}} \rangle), \quad (7)$$

together with compatibility between that forward isogeny and the encoded dual path. The honest signer creates this relation, but the verifier never tests it.

2.3 A specification tuple inconsistency

The NGCC specification contains a tuple inconsistency about c . Table 1.5 states that a compact signature contains the challenge. Algorithm 3.6, line 20, compares a variable `chl` with the hash, and Table 6.1 reports sizes that include a full challenge field. The reference encoding likewise serializes that field. On the other hand, Algorithm 3.5, line 47, and the input tuple printed for Algorithm 3.6 omit it.

If those tuple omissions are read literally, verification refers to an undefined value and the scheme is incomplete. The coherent interpretation supported by the notation table, size table, KAT modes, and executable submission is Equation (4): c is transmitted and compared with the hash. The attack applies to that submitted interpretation. Adding c to the printed tuples resolves the syntax but does not add the missing relation (7).

3 Universal message retargeting

Let $(pk, sk) \leftarrow \text{KeyGen}$ and request a signature on any message m_0 :

$$\sigma_0 = (\rho, t, g, c_0) \leftarrow \text{Sign}(sk, m_0).$$

For any fresh target message $m_1 \neq m_0$, perform the following public computation.

1. Compute $(E_{\text{chl}}, E_{\text{com}}) = \text{Recover}(pk, \rho, t, g)$ exactly as the verifier.
2. Compute

$$c_1 = \text{HASH}(pk \parallel j(E_{\text{com}}) \parallel m_1).$$

3. Output

$$\sigma_1 = (\rho, t, g, c_1).$$

Only the challenge field is replaced. The attacker does not modify either isogeny path.

Theorem 1 (One-query universal forgery for the submitted compact mode). *Assume honest compact signatures are accepted. The transform above wins the EUF-CMA game against the NGCC compact mode after one signing query. It succeeds for every fresh target message m_1 and requires one public commitment reconstruction and one evaluation of HASH.*

Proof. Because σ_0 is accepted, Equation (6) gives $P(pk, \rho, t, g) = 1$. The forgery keeps every input to P unchanged, so the same predicate remains true. Recovery from σ_1 also receives exactly the original (ρ, t, g) and therefore returns the same E_{chl} and E_{com} . By construction, the new field satisfies

$$c_1 = \text{HASH}(pk \parallel j(E_{\text{com}}) \parallel m_1).$$

Both conjuncts in Equation (6) hold, hence $\text{Verify}(pk, m_1, \sigma_1) = 1$. The message m_1 was never submitted to the signing oracle, so (m_1, σ_1) is a valid EUF-CMA forgery. $\square$

Corollary 2. *One submitted compact signature can be retargeted independently to arbitrarily many fresh messages. Neither the size of the challenge space nor the number of iterated SM3 calls changes the success probability.*

The result does not ask for a collision. The attacker evaluates the hash honestly for each new message and writes its output into a field that verification treats as independent data. Likewise, the attacker does not solve an isogeny problem: `Recover` is the public algorithm needed for ordinary verification. The hash input order used by the reference code differs cosmetically from the displayed specification order, but the attacker calls the same submitted hash routine, so either ordering admits the transform.

4 Reference-code validation

4.1 Source-level data flow

The compact branch of the Level1-`eff` reference verifier illustrates the common code path. Lines 1136–1186 of `sqsign/sign.c` recover and standardize E_{chl} using the public key and non-challenge signature fields. Lines 1188–1201 derive the dual kernel solely from `sig->ind`, `sig->scalar`, and the basis hints, then evaluate it to obtain E_{com} . Only after this reconstruction do lines 1203–1205 read `sig->chall`, comparing it with the new hash. No earlier or later operation uses that field.

Table 1: End-to-end compact-signature retargeting. Every fresh forgery was accepted.

Parameter set	b	Signature bytes	Offset bytes	Field bytes	Median ms	Range ms
Level1-eff	78	168	64	16	63	56–67
Level1-sec	84	178	68	17	71	70–88
Level2-eff	96	208	80	20	20	19–20
Level2-sec	101	218	84	21	161	128–163
Level3-eff	156	326	128	31	340	334–346
Level3-sec	163	338	132	33	456	344–478
Level5-eff	319	648	256	64	1978	957–2220
Level5-sec	334	678	268	67	1689	668–1869

The serialized layout makes the transformation particularly simple. In compact mode, `pack.c` writes the encoded curve first and the challenge immediately afterward (lines 232–235); decoding uses the same order (lines 301–305). The attacker replaces the contiguous byte interval

$$[\text{FP2_ENCODED_BYTES}, \text{FP2_ENCODED_BYTES} + \text{NWORDS_ORDER_3_BYTES}) \quad (8)$$

and copies every other byte verbatim.

The seven non-Level1-eff instances have byte-identical `sign.c` files. The Level1-eff file differs only in unrelated source details and has the same data flow. The attack harness links the original key generation, signing, parsing, hashing, and verification sources without editing them. Its attacker-side routine copies the verifier’s public reconstruction through the point where E_{com} is available, invokes the submission’s `hash_to_challenge` routine, and reserializes the signature.

4.2 Method and controls

For each of the eight submitted parameter sets we compiled the portable reference sources with `-O2 -DNDEBUG -DCOMPRESSED=1`, GCC 13.3.0, and GMP 6.3.0. The independent reproduction ran on 64-bit Linux on a four-core Intel Core i5-6500 processor. It generated one key pair and one signature on m_0 , then retargeted that signature to three distinct fresh messages. The same public transform and controls were fixed for every parameter set.

Each trial checked all of the following:

1. the honest signature is accepted on m_0 ;
2. the untouched signature is rejected on a fresh message;
3. the retargeted signature is accepted on its fresh message;
4. the retargeted signature is rejected on m_0 ; and
5. all bytes outside the interval in Equation (8) are unchanged.

The reported forgery time includes signature parsing, both public isogeny reconstructions, all configured hash grinding, replacement, and serialization. It excludes key generation and the single oracle signature. Times are the median and range of the three fresh targets.

All 24 fresh-message forgeries passed every check. Every measured transform completed within 2.23 seconds. The controls establish that acceptance was caused by the new challenge field, while the byte comparison establishes that no response component was altered. The measured key-generation and one-oracle-signature times are excluded from the attack timings; the signing query is supplied by the EUF-CMA oracle.

For artifact identification, the tested specification PDF has SHA-256 digest

598139DA24C326890600CED289C41E62
1E7DF5F1612EF3C1C699E620E33FB1EC

5 Scope of the result

5.1 The defect is in the submitted compact verification relation

The proof uses the acceptance structure printed in Algorithm 3.6 of the NGCC submission: recover E_{chl} from the response, recover E_{com} from (t, g) , and compare a challenge value with the hash. Equation (7) is absent from that algorithm. Thus the attack is not created by a parser discrepancy or a reference-only shortcut. It is a flaw in the verification relation specified and implemented for the submitted compact mode.

The submitted reference verifier performs an additional common-part check after the hash comparison. This does not help because the transform leaves the entire response and dual path unchanged. Any corrected or strengthened predicate depending only on those original fields has the same truth value before and after retargeting. The attack would fail only if verification made the recomputed challenge constrain the forward challenge isogeny.

5.2 Distinction from the original published compact construction

The earlier SQIsign2D2 paper describes a different compact binding mechanism in Algorithms 8 and 9 [2]. Its signature contains a dual-kernel point P_2 and a scalar, denoted t there. Verification deterministically chooses a complementary point Q_2 , evaluates the dual challenge isogeny $\hat{\phi}$ with kernel $\langle P_2 \rangle$, sets $L = \hat{\phi}(Q_2)$, derives the forward-kernel generator K_1 from the message and reconstructed commitment, and requires

$$K_1 = [t]L. \tag{9}$$

That equality directly binds the message-derived challenge to the transmitted dual path.

The NGCC submission uses the name t for a projective description of the dual kernel and adds a transmitted scalar c . It omits Equation (9); its final check is the detached comparison $c = \text{HASH}(pk \parallel j(E_{\text{com}}) \parallel m)$. The present attack targets that submitted change. It does not show that Algorithms 8 and 9 of the 2025 paper are vulnerable to the same retargeting transform.

5.3 Public findings and the uncompressed mode

As of 28 September 2026, the public NGCC tracker lists two earlier SQIsign2D2 findings: **sign-25-1**, a stale-stack verifier failure in the Level2-eff uncompressed reference implementation, and **sign-25-2**, a parameter-sizing lead based on improved isogeny algorithms [3]. Neither finding is the deterministic compact-signature retargeting described here.

The uncompressed verifier receives E_{com} directly, recomputes the challenge from the message, and uses that result to form the kernel $\langle R_{\text{com}} + [c]S_{\text{com}} \rangle$ before checking the response. Changing the message therefore changes an input to the geometric verification. The detached-field transform in this note does not apply to that mode.

The present proof assumes an honest, valid compact signature and changes only its challenge bytes. It neither uses malformed input nor depends on process state. It remains valid if all input validation and common-part checks are implemented as intended, provided the detached challenge comparison is left unchanged.

5.4 Security impact

The EUF-CMA definition in the SQIsign2D2 specification follows the standard adaptive chosen-message game [5]. The adversary here asks for one signature on m_0 and returns an accepted pair for a distinct, unqueried m_1 . This directly violates the definition. Since m_1 may be selected after receiving the oracle signature, the failure is stronger than a same-message encoding malleability result.

The claimed classical security levels of 128, 160, 256, and 512 bits do not enter the attack. Its cost is comparable to one compact verification and took at most 2.23 seconds in the submitted portable reference parameter sets tested.

6 Repair

A repair must make the hash output select the same challenge isogeny that the response uses. Merely recomputing or reserializing c is insufficient.

One option is to restore the binding relation of the original compact construction: transmit the data needed to define P_2 and the binding scalar, reconstruct $L = \widehat{\phi}(Q_2)$, and check Equation (9) against the hash-derived forward-kernel generator. The notation must distinguish that binding scalar from any projective scalar used only to encode the dual kernel.

Another direct repair for the submitted encoding is:

1. reconstruct E_{chl} and E_{com} from the compact response and dual-path data;
2. compute $c = \text{HASH}(pk \parallel j(E_{\text{com}}) \parallel m)$ internally, without trusting a transmitted copy;
3. derive a canonical basis $(R_{\text{com}}, S_{\text{com}})$ of $E_{\text{com}}[3^b]$;
4. evaluate the forward isogeny with kernel $\langle R_{\text{com}} + [c]S_{\text{com}} \rangle$; and
5. verify that its standardized codomain and dual kernel agree with the reconstructed E_{chl} and the encoded (t, g) path.

At minimum, the codomain equality in Equation (7) must hold. Checking dual kernel compatibility as well avoids relying on uniqueness of a path from codomain data alone. The specification should also state one consistent signature tuple and include this invariant in the security proof and test suite. A regression test can take an honest compact signature, rehash its reconstructed commitment under a different message, replace the challenge field, and require rejection.

Removing the transmitted c field after deriving it internally would reduce ambiguity, but it does not by itself provide security: the internally derived value still has to be used in the forward-path check.

7 Conclusion

The NGCC CompactSQIsign2D2 verifier checks a response path and a Fiat–Shamir digest as two separate facts. It does not verify the relation that makes the digest the challenge for that path. This decoupling turns any one valid submitted compact signature into signatures for arbitrary fresh messages by replacing only the challenge field. The transform is deterministic, public, independent of isogeny hardness, and validated against every submitted compact parameter set in at most 2.23 seconds on the test laptop. Restoring an explicit forward-to-dual binding, as in the original published compact construction, prevents this retargeting attack.

References

- [1] Zheng Xu, Keteng Huang, Yi Ouyang, Jiankuo Dong, Liang Bai, Yijing Ning, Wei Wei, and Honggang Hu. *SQIsign2D2: Algorithm Specifications and Supporting Documentation*. Version 1.0, NGCC submission, 26 April 2026.
- [2] Zheng Xu, Kaizhan Lin, Chang-An Zhao, and Yi Ouyang. SQIsign2D²: New SQIsign2D Variant by Leveraging Power Smooth Isogenies in Dimension One. Cryptology ePrint Archive, Paper 2025/920, 2025. <https://eprint.iacr.org/2025/920>.
- [3] Markku-Juhani O. Saarinen, editor. SQIsign2D2 (sign-25), NGCC public security tracker. Accessed 28 September 2026. <https://ngcc.dev/reports/sign-25.html>.
- [4] Amos Fiat and Adi Shamir. How to Prove Yourself: Practical Solutions to Identification and Signature Problems. In *Advances in Cryptology – CRYPTO ’86*, LNCS 263, pages 186–194. Springer, 1987.
- [5] Shafi Goldwasser, Silvio Micali, and Ronald L. Rivest. A Digital Signature Scheme Secure Against Adaptive Chosen-Message Attacks. *SIAM Journal on Computing*, 17(2):281–308, 1988.